

Experiment 2: Cross-Site Scripting (XSS) using Juice Shop and Burp Suite

Prerequisites:

OWASP Juice Shop is installed and running on <http://localhost:3000>

Pull the OWASP Juice Shop Docker Image

Open **Terminal / Command Prompt** and run:

`docker pull bkimminich/juice-shop`

```
harivigneshrao@HARIS-MacBook-Pro ~ % docker pull bkimminich/juice-shop
Using default tag: latest
latest: Pulling from bkimminich/juice-shop
c172f21841df: Pull complete
b4242723c53f: Pull complete
3214acf345c8: Pull complete
8872b5a8f795: Pull complete
52b2cf548ae5: Pull complete
483bdc7de96: Downloading [=====>] 25.17MB/124.9MB
77d3479ca1b9: Pull complete
278aece295e: Pull complete
7c12895b777b: Pull complete
52638fc75a18: Pull complete
d6b1b89eccac: Pull complete
8cd92d02ae08: Downloading [=====>] 19.92MB/43.3MB
35d8e5f294cf: Pull complete
76274538ae4: Download complete
d564bf2dd177: Pull complete
b4e6f1bfc08a: Pull complete
bdfd77e5b5f6: Pull complete
ff43311d121d: Pull complete
b839d9ae01f6: Pull complete
f3e519d19e1f: Pull complete
ebddc55facdc: Pull complete
2780920e5dbf: Pull complete
cc446582c7c7: Pull complete
0e7df641b9d5: Pull complete
2b585e1b42d1: Download complete
```

Run the Juice Shop Container

After the image is downloaded, run:

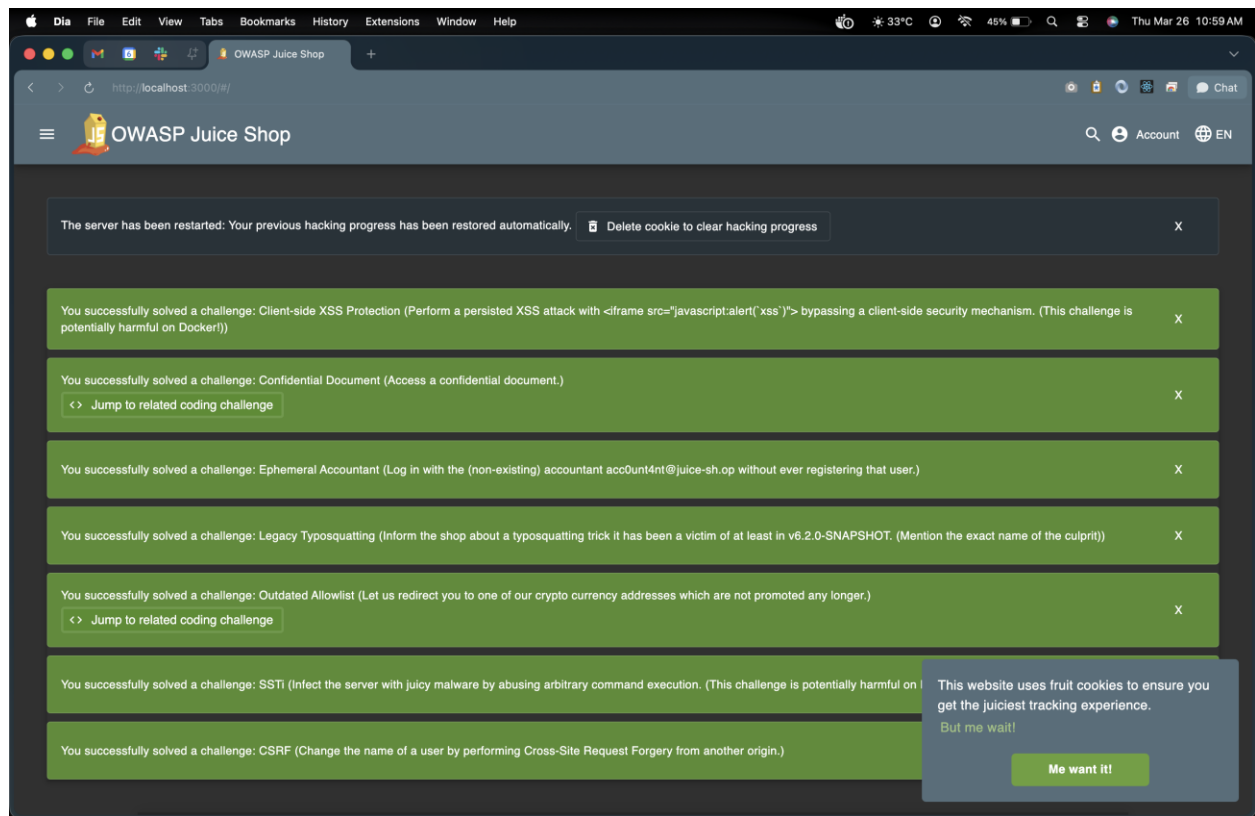
`docker run -d -p 3000:3000 bkimminich/juice-shop`

```
b4242723c53f: Pull complete
3214acf345c8: Pull complete
8872b5a8f795: Pull complete
52b2cf548ae5: Pull complete
483bdc7de96: Pull complete
77d3479ca1b9: Pull complete
278aece295e: Pull complete
7c12895b777b: Pull complete
52638fc75a18: Pull complete
d6b1b89eccac: Pull complete
8cd92d02ae08: Pull complete
35d8e5f294cf: Pull complete
76274538ae4: Pull complete
d564bf2dd177: Pull complete
b4e6f1bfc08a: Pull complete
bdfd77e5b5f6: Pull complete
ff43311d121d: Pull complete
b839d9ae01f6: Pull complete
f3e519d19e1f: Pull complete
ebddc55facdc: Pull complete
2780920e5dbf: Pull complete
cc446582c7c7: Pull complete
0e7df641b9d5: Pull complete
2b585e1b42d1: Download complete
Digest: sha256:224988f8e839bc4224a5435b272743bee7ad8f364a7d94488b7594f3bc529d8
Status: Downloaded newer image for bkimminich/juice-shop:latest
docker.io/bkimminich/juice-shop:latest
harivigneshrao@HARIS-MacBook-Pro ~ % docker run -d -p 3000:3000 bkimminich/juice-shop
c52113ea22ba0e39a9c771db5c8cb94009d947f9cfbe1c681f5e46fc1b982bef
harivigneshrao@HARIS-MacBook-Pro ~ %
```

Access OWASP Juice Shop

Open your browser and navigate to:

`http://localhost:3000`



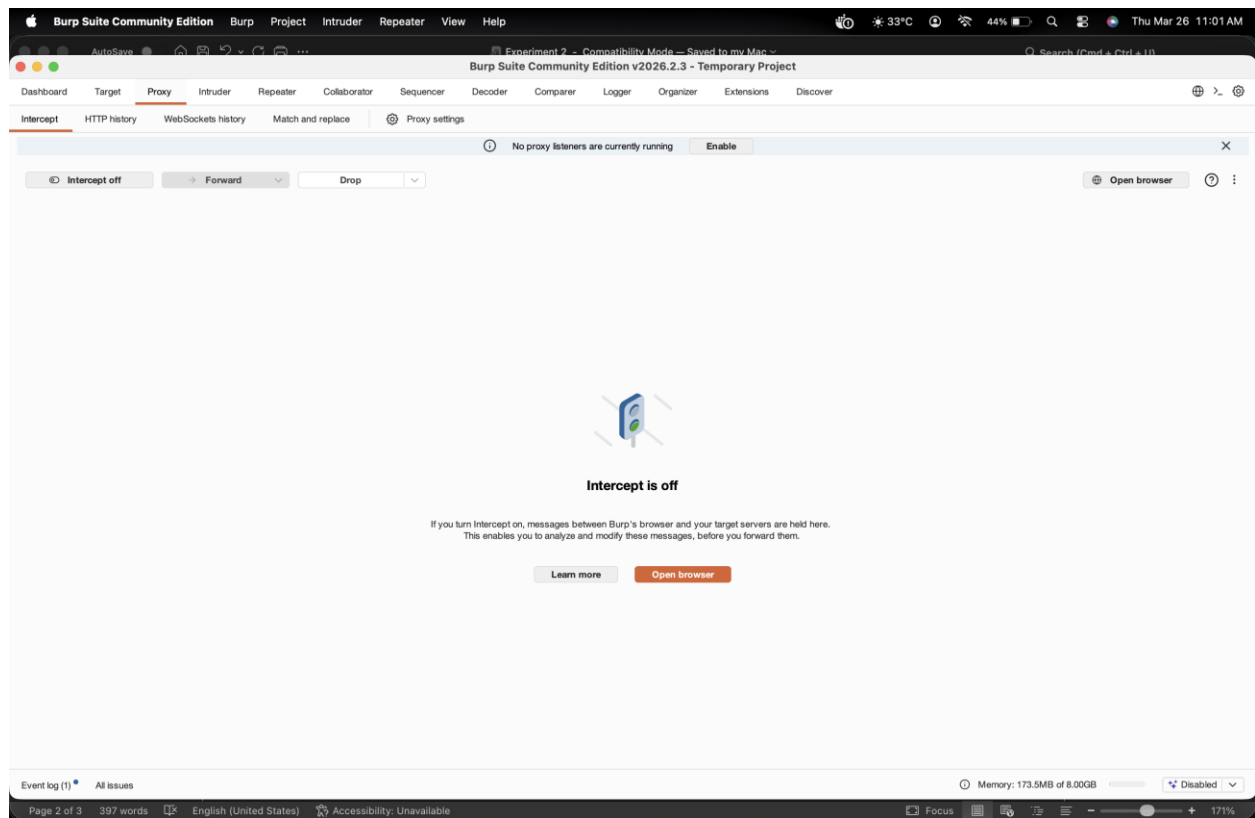
Burp Suite is installed and configured to intercept traffic

A modern web browser (Chrome/Firefox)

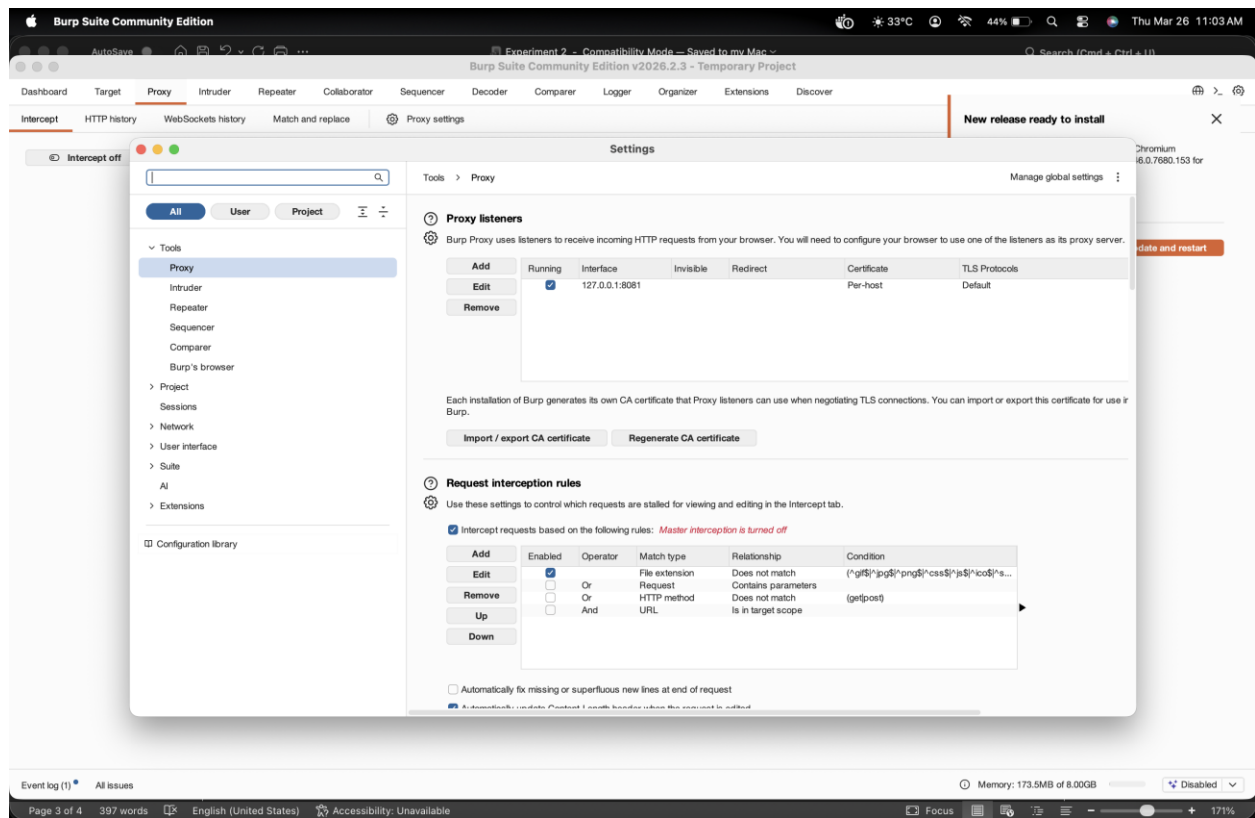
Step 1: Configure Burp Suite Proxy

1. Open Burp Suite and navigate to Proxy > Intercept.

2. Ensure Intercept is off.



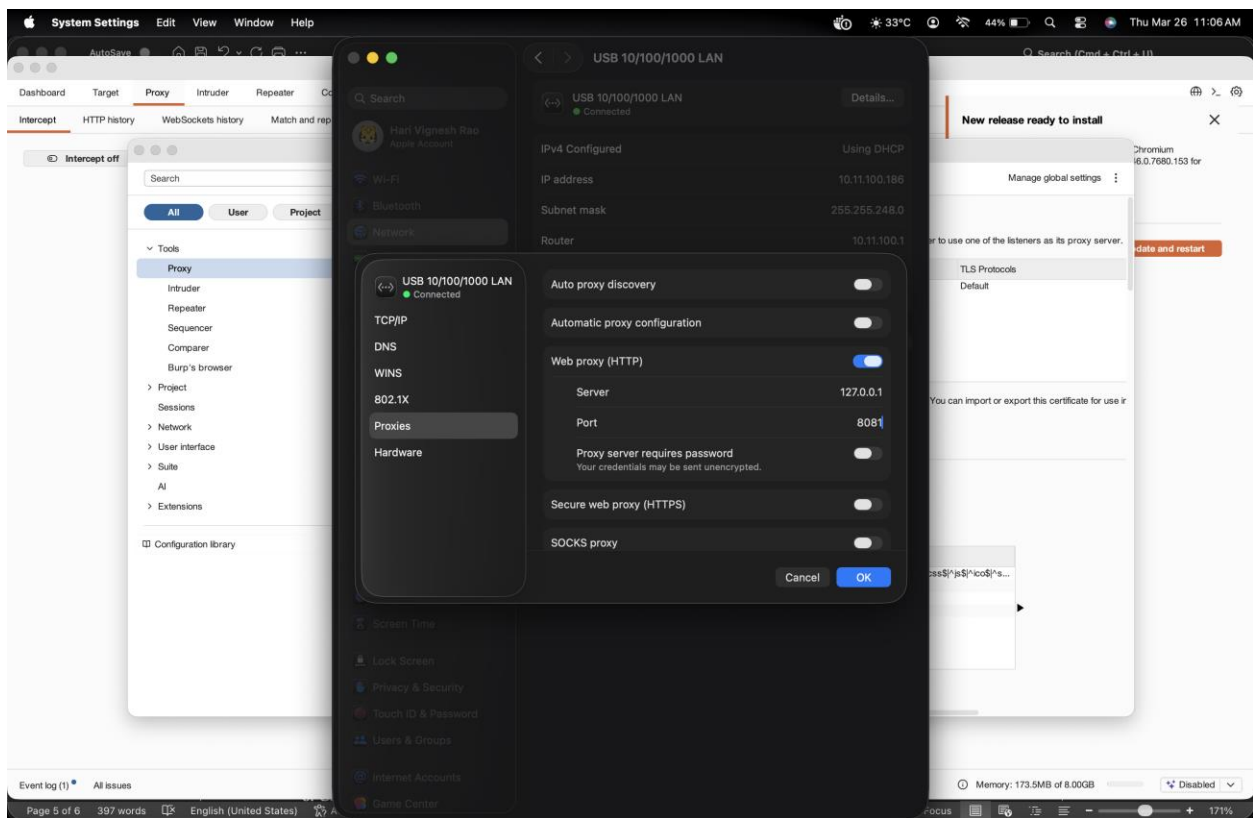
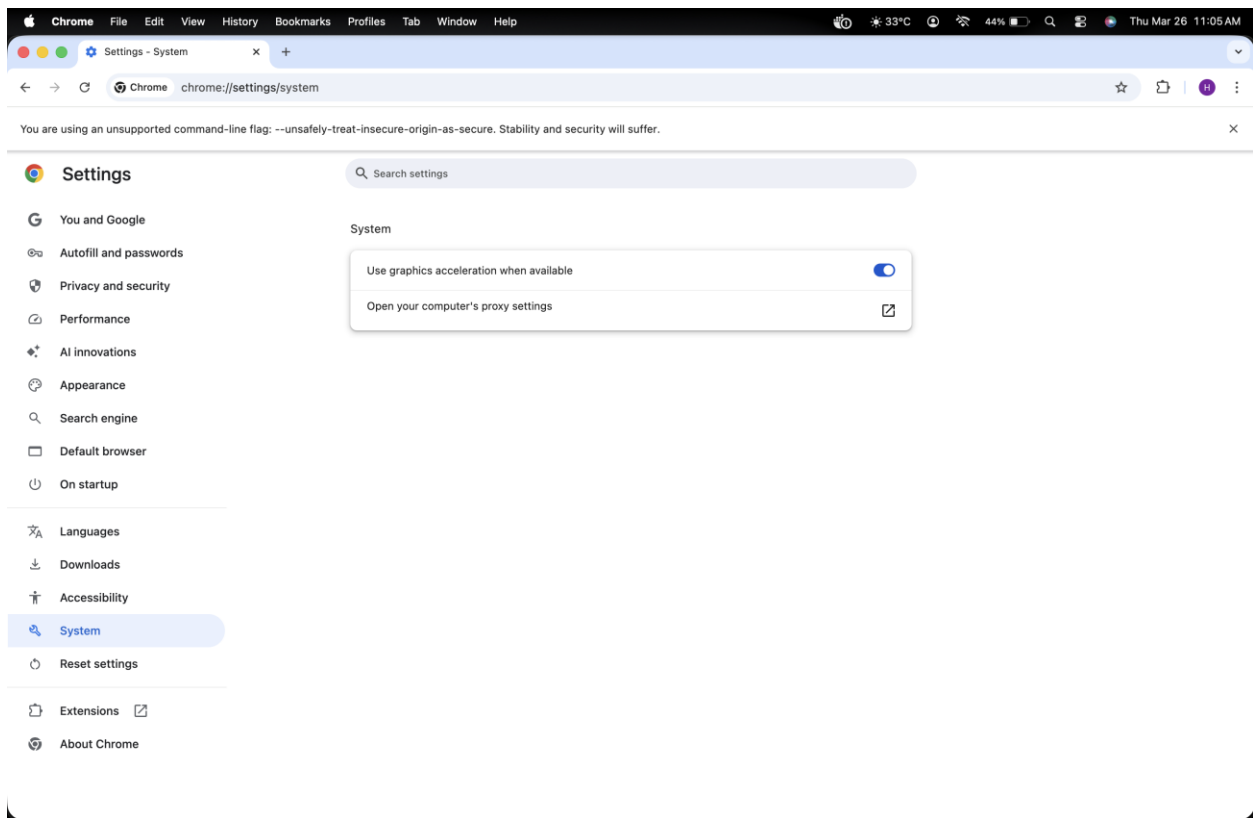
3. Go to Proxy > Options, under Proxy Listeners, check that Burp is listening on 127.0.0.1:8081.



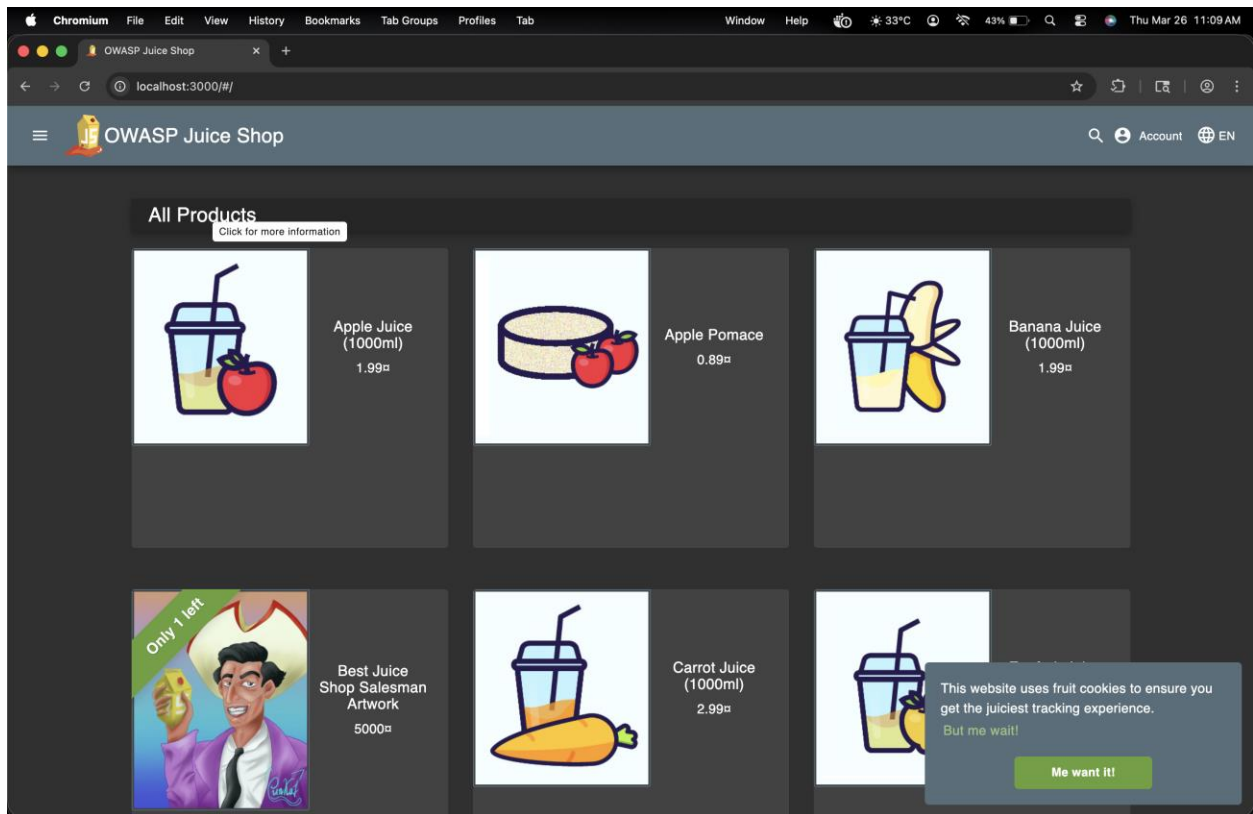
4. Open your browser and configure it to use Burp Suite as a proxy:

O Chrome: Settings > Proxy settings > Manual proxy > Set HTTP Proxy to 127.0.0.1, Port 8081.

O Firefox: Preferences > Network Settings > Manual proxy > Set HTTP Proxy to 127.0.0.1, Port 8081.



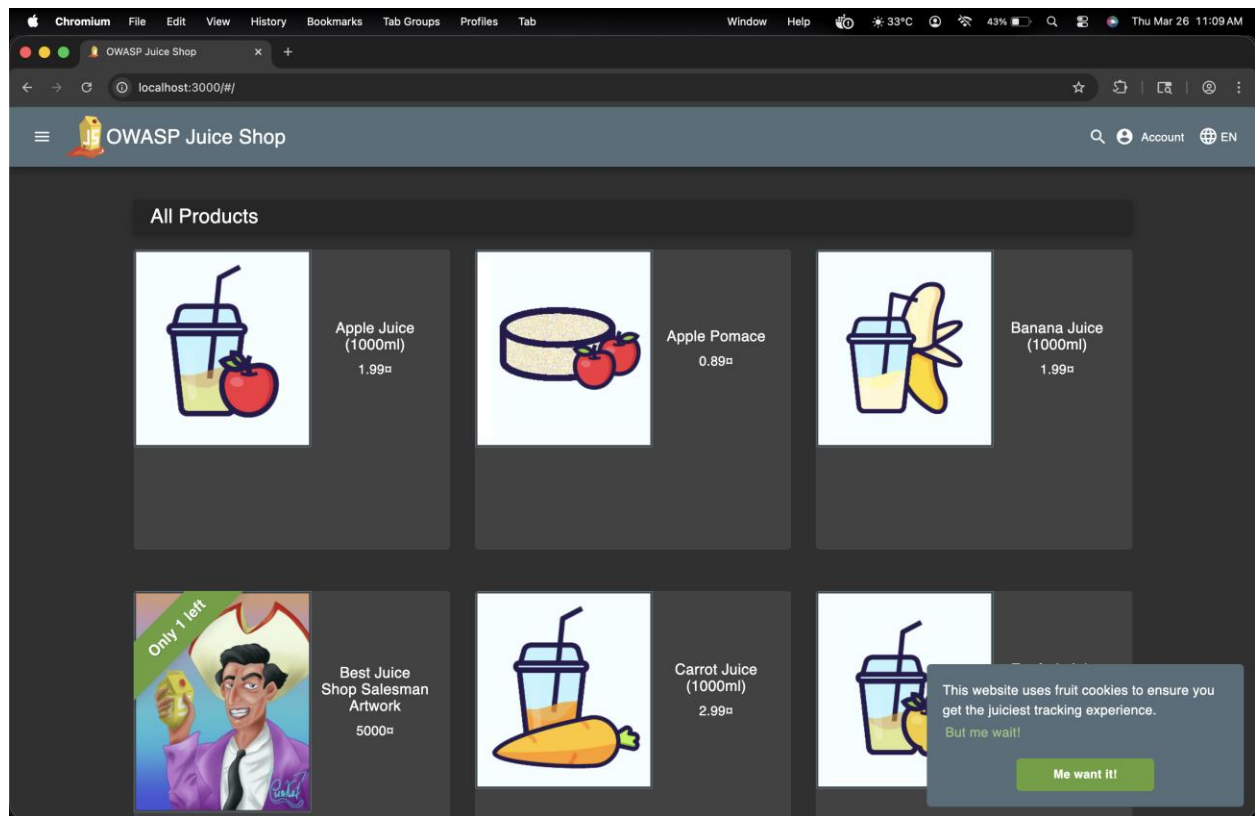
5. Verify by opening <http://localhost:3000> in your browser while Burp Suite is running. Requests should appear in HTTP history.



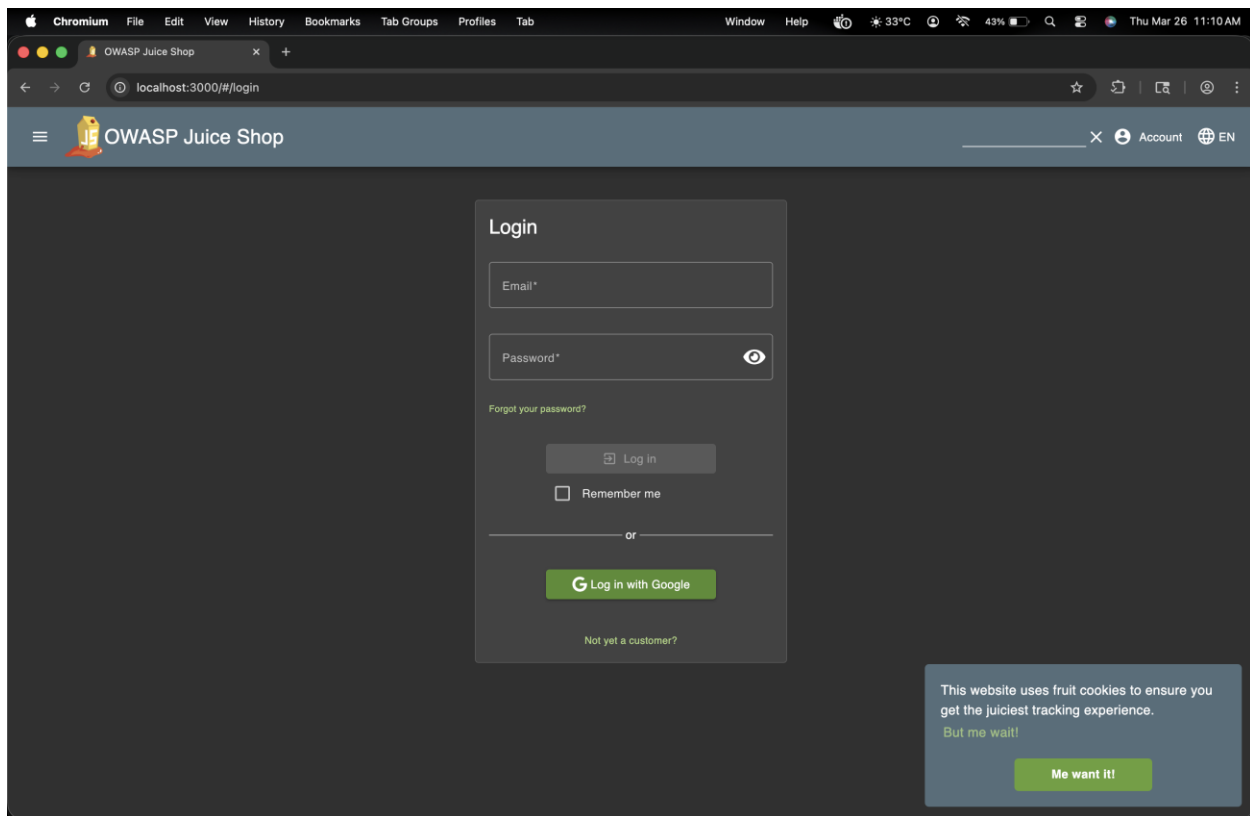
#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start response
1	http://localhost:3000	GET	/			200	75471	HTML		OWASP Juice Shop			127.0.0.1		11:07:45 26 ...	8081	10
11	http://localhost:3000	GET	/assets/1f8v/en.json			200	33643	JSON	json				127.0.0.1		11:07:45 26 ...	8081	1
12	http://localhost:3000	GET	/socket.io/?EIO=4&transport=polling...		✓	200	326	text	io/				127.0.0.1		11:07:45 26 ...	8081	1
13	http://localhost:3000	GET	/rest/admin/application-configuration			200	22159	JSON					127.0.0.1		11:07:45 26 ...	8081	27
14	http://localhost:3000	GET	/rest/admin/application-version			200	404	JSON					127.0.0.1		11:07:45 26 ...	8081	11
15	http://localhost:3000	GET	/rest/languages			200	4623	JSON					127.0.0.1		11:07:45 26 ...	8081	81
16	http://localhost:3000	GET	/api/challenges/?name=Score%20...		✓	200	835	JSON					127.0.0.1		11:07:45 26 ...	8081	137
17	http://localhost:3000	GET	/api/quantities/			200	6646	JSON					127.0.0.1		11:07:45 26 ...	8081	144
18	http://localhost:3000	GET	/rest/products/search?q=		✓	200	14033	JSON					127.0.0.1		11:07:45 26 ...	8081	99
20	http://localhost:3000	POST	/socket.io/?EIO=4&transport=polling...		✓	200	215	HTML	io/				127.0.0.1		11:07:45 26 ...	8081	13
22	http://localhost:3000	GET	/socket.io/?EIO=4&transport=polling...		✓	200	262	text	io/				127.0.0.1		11:07:45 26 ...	8081	17
23	http://localhost:3000	GET	/rest/admin/application-version			304	304						127.0.0.1		11:07:45 26 ...	8081	2
24	http://localhost:3000	GET	/rest/admin/application-configuration			304	304						127.0.0.1		11:07:45 26 ...	8081	1

Step 2: Identify XSS Vulnerabilities

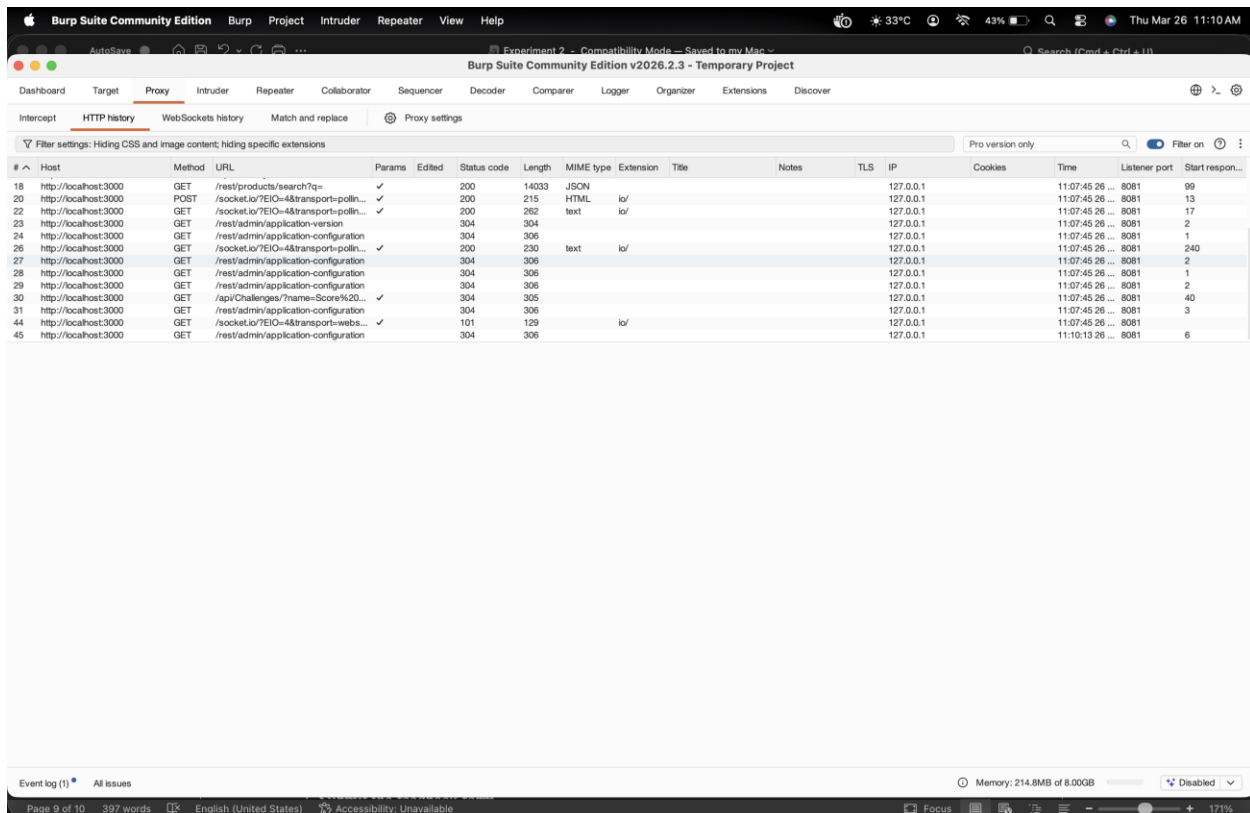
1. Open <http://localhost:3000> in the browser.



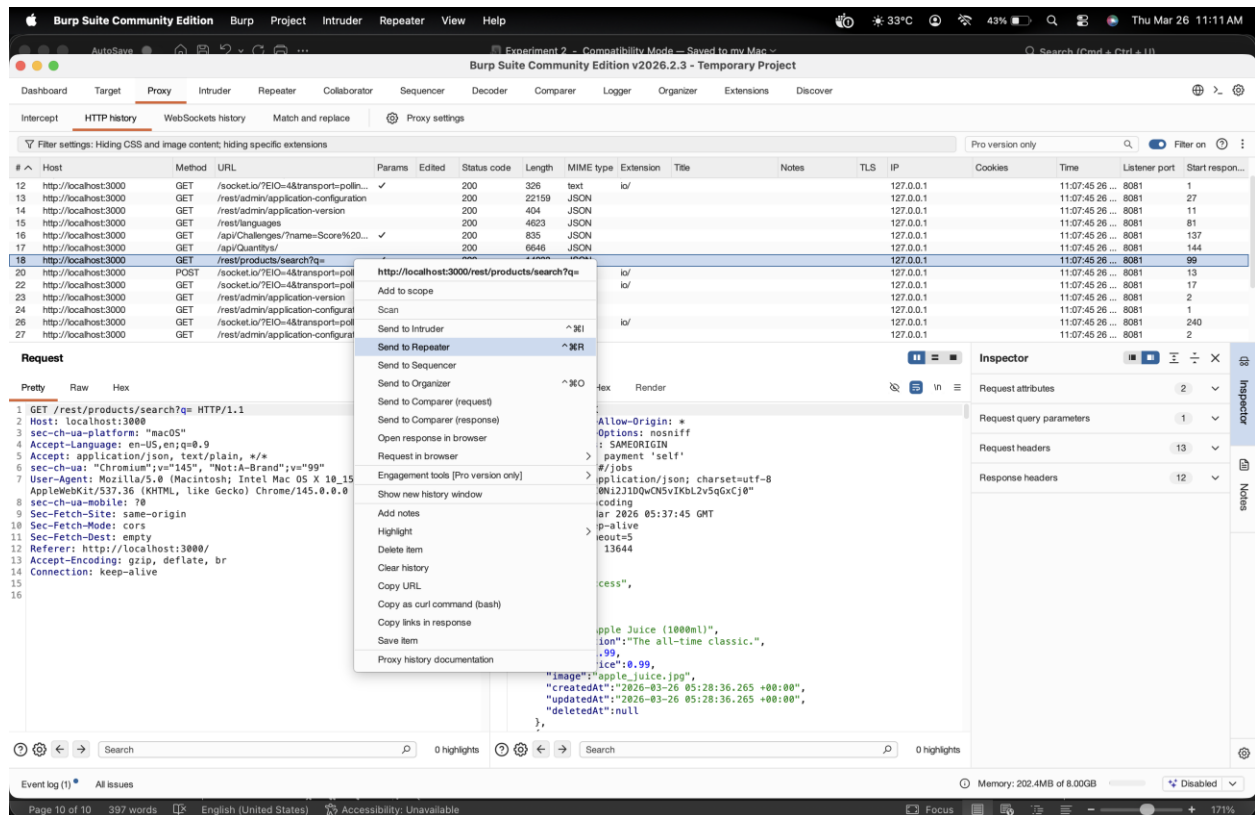
2. Browse through different sections of Juice Shop and look for input fields (such as search bars, login forms, and feedback forms).



2. Open Burp Suite and navigate to Proxy > HTTP history.

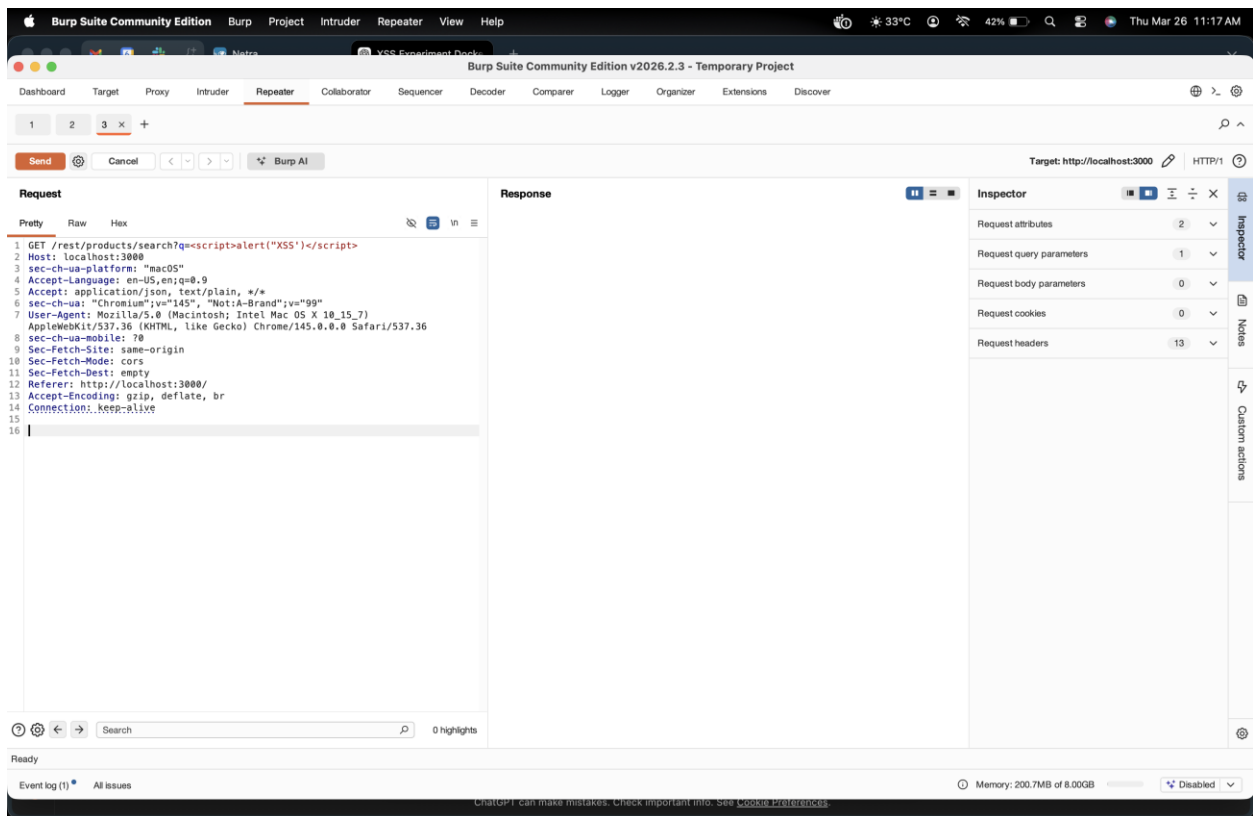


4. Locate the request corresponding to an input field and send it to Repeater (Right-click > Send to Repeater).

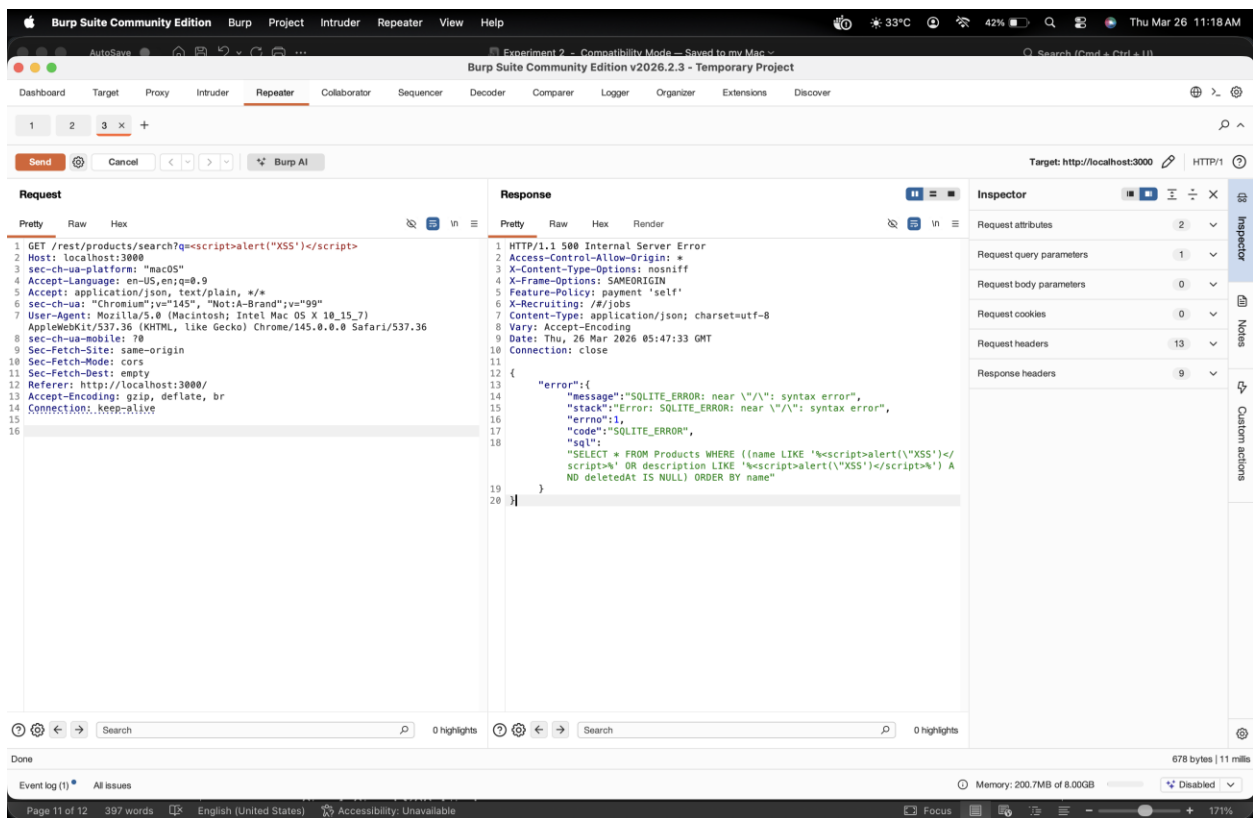


5. In the Repeater tab, experiment by modifying the input fields with JavaScript payloads such as:

```
<script>alert('XSS')</script>
```

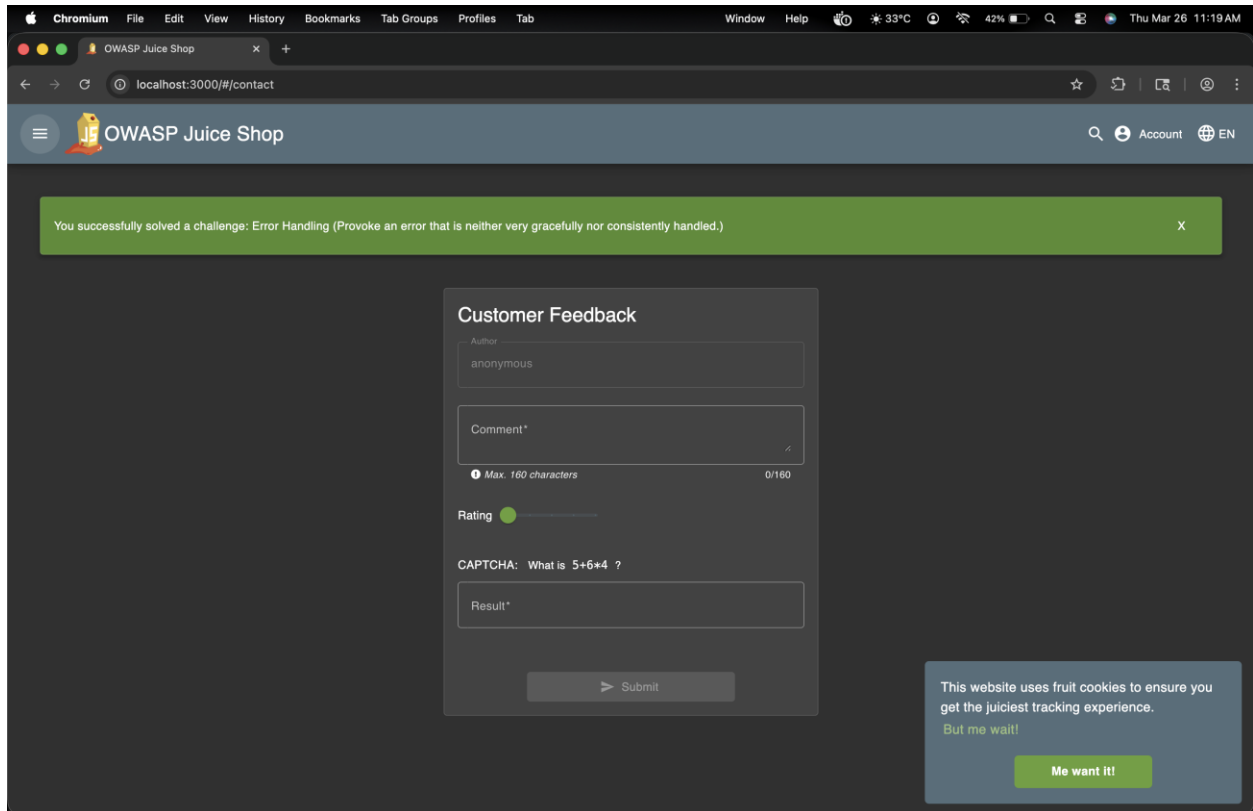


6. Click Send and observe the response for execution of the script.



Step 3: Exploiting XSS in Feedback Form

1. In Juice Shop, navigate to Contact Us or Feedback page.



2. Enter the following payload in the comment field: `<script>alert("XSS")</script>`

Chromium File Edit View History Bookmarks Tab Groups Profiles Tab Window Help 33°C 41% Thu Mar 26 11:22 AM

OWASP Juice Shop

localhost:3000/#/contact

Account EN

Customer Feedback

Author
anonymous

Comment*
<script>alert("XSS")</script>

Max: 160 characters 29/160

Rating

CAPTCHA: What is $3+10+7$?

Result*
37

Submit

This website uses fruit cookies to ensure you get the juiciest tracking experience.
But me wait!

Me want it!

3. Submit the feedback form.

Chromium File Edit View History Bookmarks Tab Groups Profiles Tab Window Help 33°C 41% Thu Mar 26 11:23 AM

OWASP Juice Shop

localhost:3000/#/contact

Account EN

Customer Feedback

Author
anonymous

Comment*

Max: 160 characters 0/160

Rating

CAPTCHA: What is $2-9-1$?

Result*

Submit

Thank you for your feedback.

This website uses fruit cookies to ensure you get the juiciest tracking experience.
But me wait!

Me want it!

4. If the site is vulnerable, an alert box will pop up.

5. Confirm the XSS attack by checking:

○ The browser console (F12> Console).

○ The HTTP history tab in Burp Suite.

Inspecting the request and response in Burp Suite.

The screenshot displays the Burp Suite Community Edition interface. The top menu bar includes options like Dashboard, Target, Proxy, Intruder, Repeater, View, and Help. The main window is divided into several panes. The 'HTTP history' pane shows a list of intercepted requests. The selected request is a POST to /api/feedbacks/ with a status code of 201. The 'Request' pane shows the raw HTTP request, including headers like Content-Type: application/json and User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36. The 'Response' pane shows the raw HTTP response, including headers like Access-Control-Allow-Origin: * and a JSON body indicating success. The 'Inspector' pane on the right shows the request and response details, including cookies and headers.

Step 4: Stored XSS Attack

1. Locate a form where the input is stored and displayed later (e.g., user profile, reviews, or feedback section).

2. Enter the payload:

```
<script>document.write('<img src=x onerror=alert("Stored XSS")>');</script>
```

Burp Suite Community Edition v2026.2.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start respon...
579	http://localhost:3000	GET	/rest/captcha/			200	433	JSON					127.0.0.1		11:40:18.26...	8081	89
580	http://localhost:3000	GET	/rest/user/whoam?fields=id,email		✓	304	303						127.0.0.1		11:40:18.26...	8081	19
582	http://localhost:3000	POST	/socket.io/?EIO=4&transport=polling		✓	200	215	HTML	io/				127.0.0.1		11:40:18.26...	8081	2
583	http://localhost:3000	GET	/socket.io/?EIO=4&transport=websockets		✓	101	129		io/				127.0.0.1		11:40:18.26...	8081	3
585	http://localhost:3000	GET	/rest/admin/application-configuration		✓	304	306						127.0.0.1		11:40:18.26...	8081	6
586	http://localhost:3000	GET	/socket.io/?EIO=4&transport=polling		✓	200	262	text	io/				127.0.0.1		11:40:18.26...	8081	3
587	http://localhost:3000	GET	/rest/admin/application-version		✓	304	304						127.0.0.1		11:40:18.26...	8081	15
589	http://localhost:3000	GET	/rest/admin/application-configuration		✓	304	306						127.0.0.1		11:40:18.26...	8081	17
590	http://localhost:3000	GET	/rest/admin/application-configuration		✓	304	306						127.0.0.1		11:40:18.26...	8081	1
591	http://localhost:3000	GET	/api/challenges/?name=Score%20...		✓	304	305						127.0.0.1		11:40:18.26...	8081	6
592	http://localhost:3000	POST	/api/feedbacks/		✓	201	584	JSON					127.0.0.1		11:40:52.26...	8081	24
593	http://localhost:3000	GET	/rest/captcha/		✓	200	431	JSON					127.0.0.1		11:40:52.26...	8081	22
594	http://localhost:3000	GET	/rest/user/whoam?fields=id,email		✓	304	303						127.0.0.1		11:40:52.26...	8081	8

Request

Pretty Raw Hex

```
1 POST /api/feedbacks/ HTTP/1.1
2 Host: localhost:3000
3 Content-Length: 145
4 sec-ch-ua-platform: "macOS"
5 Accept-Language: en-US,en;q=0.9
6 Accept: application/json, text/plain, */*
7 sec-ch-ua: "Chromium";v="145", "Not(A:Brand";v="99"
8 Content-Type: application/json
9 sec-ch-ua-mobile: ?0
10 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
11 Origin: http://localhost:3000
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: http://localhost:3000/
16 Accept-Encoding: gzip, deflate, br
17 Cookie: language=en; welcomebanner_status=dismiss; continueCode=Zv5LK9Vzj81YlXaPmeb9pT0cXfz5mYzYtg2T5o6xo0NB6q74R2My0JkrQE
18 Connection: keep-alive
20 {
  "captchaId":15,
  "captcha":"84",
  "comment":
    "<script>document.write('<img src=x onerror=alert('Stored XSS')>')</script> (anonymous)",
  "rating":2
}
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 201 Created
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 Location: /api/feedbacks/16
8 Content-Type: application/json; charset=utf-8
9 Content-Length: 165
10 ETag: W/"a5-13bmeN/+3oTPC8AN3IjmxXFGv15o"
11 Vary: Accept-Encoding
12 Date: Thu, 26 Mar 2026 06:10:52 GMT
13 Connection: keep-alive
14 Keep-Alive: timeout=5
15
16 {
  "status":"success",
  "data":{
    "id":16,
    "comment":" (anonymous)",
    "rating":2,
    "updatedAt":"2026-03-26T06:10:52.668Z",
    "createdAt":"2026-03-26T06:10:52.668Z",
    "userId":null
  }
}
```

Inspector

Request attributes 2

Request cookies 3

Request headers 17

Response headers 13

Event log (2) All issues

Memory: 214.5MB of 8.00GB Disabled

Chromium File Edit View History Bookmarks Tab Groups Profiles Tab Window Help

localhost:3000/#/contact

OWASP Juice Shop

Account EN

Customer Feedback

Author: anonymous

Comment: <script>document.write('')</script>

Max. 160 characters 75/160

Rating: [Progress bar]

CAPTCHA: What is 4-7-8 ?

Result: -11

Submit

This website uses fruit cookies to ensure you get the juiciest tracking experience. But me wait!

Me want it!

3. Submit the form.

4. Reload the page where the stored input is displayed.